

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s) What factors contributed to the information leak?	Mishandling of data and human error are the contributing factors that lead to the leakage of internal-only documents. Access to the internal folder was not limited to the sales team and the manager. The business partner should not have been given permission to share the promotional information to social media. Failure to apply the Principle of Least Privilege is also a factor, as it results in unauthorized individuals gaining access.
Review What does NIST SP 800-53: AC-6 address?	NIST SP 800-53 is a set of guidelines for securing the privacy of information systems. It helps implement controls that are used by the manufacturer to protect against data leaks.
Recommendation(s) How might the principle of least privilege be	Two control enhancements that might have prevented the data leak; ● Restrict access to sensitive resources based on user role. ● Regularly audit user privileges.

improved at the company?	Automatically revoke access to information after a period of time.
Justification How might these improvements address the issues?	To reduce the likelihood of another data leak, applying the principle of least privilege is an important practice to prevent unauthorized access to sensitive information. These control enhancements might prevent future data leaks. Data leaks can be prevented if shared links to internal files are restricted to employees only. Also, requiring managers and security teams to regularly audit access to team files would help limit the exposure of sensitive Information. Automatically revoke access if the user already perform the task required or creating a policy that sets expiration dates for access links might have avoided the leak.

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.